FUND-CRITICAL BUG HUNT · LIVE TARGET #1

Vena Finance

Lending • Fluent (chainID 25363) • TVL ~$24M • Audits 0 • 2026-06-13

Methodology: Fund-Critical Bug-Hunt Codex (A/C/H series) • keyless on-chain verification

VERDICT: CLEAN CORE / RESIDUAL ORACLE DESIGN RISK — NO PUSH-BUTTON FUND-CRITICAL BUG FOUND AT CURRENT ON-CHAIN STATE. LENDING CORE IS CANONICAL, UNMODIFIED AAVE V3; SOLE BESPOKE SURFACE IS A DEFENSIVELY-WRITTEN PYTH ORACLE LAYER.

1 • Protocol Map (verified on-chain)

Vena is an **Aave V3 fork** (Solidity 0.8.10) with a custom Pyth Lazer oracle layer. All contracts verified on FluentScan.

COMPONENT	ADDRESS	NOTES
PoolAddressesProvider	`0xf5569e98…141983`	registry
Pool (proxy)	`0xd6e69976…f14013`	impl 0xd5443A…E5753
AaveOracle	`0xc3be4ddd…a353db`	BASE=USD, UNIT=1e8
ACLManager	`0x18797a36…7369bf`	role gate
VenaPythPrices	`0xc93Dd129…3b905`	Pyth Lazer store

Reserves (3)

ASSET	DEC	LTV	LIQTHRESH	BORROW	ORACLE ADAPTER
WETH	18	65%	68%	yes	PythProAggregatorAdapter (feed 631)
sUSDnr	6	66%	73%	no	AggregatedPythPriceAdapter (3176×3221)
USDnr	6	75%	78%	yes	PythProAggregatorAdapter (feed 3176)

2 • What Was Tested

ALGO	CHECK	RESULT
A1	Lending core vs canonical Aave V3	CLEAN — supply/borrow/withdraw/liquidationCall/flashLoan delegate unmodified to standard logic libraries. Only custom files: PoolConfiguratorV2 (revision bump) + EmptyContract (build stub).
A2 RRL	aToken round-trip residual sweep across live indices	CLEAN — ray-math round-trips (supply→withdraw) yield **zero residual** at all amounts (1 wei … 1e19) for all reserves.
A3 CDDS	Decimal-domain sweep (18-dec WETH + 6-dec stables)	RESIDUAL — mixed decimals handled correctly by Aave core; risk lives in the oracle scaling assumption → Finding 1.
Oracle	Staleness • role-gating • sig verification • timestamp skew	CLEAN — 60s staleness (tight), PRICE_UPDATER_ROLE writes, Pyth Lazer signature verification, TimestampMismatch guard on dual-feed aggregator.
Access	Who can move prices	Attacker **cannot** inject prices: writes need role **and** valid Pyth Lazer signature.

3 • Findings — Residual / Design Risk

Not currently exploitable. Reported per Codex integrity rule: no bug is claimed without a runnable proof artifact, and none exists here.

Finding 1 — Unvalidated Pyth exponent invariant

LATENT HIGH · NOT CURRENTLY TRIGGERABLE · A3-CLASS DECIMAL BUG

`PythProAggregatorAdapter.latestAnswer()` returns the **raw uint64 Pyth price** without applying the feed exponent:

```
function latestAnswer() external view returns (int256) {
    (uint64 price, uint64 timestamp) = i_venaPythPrices.getLatestPriceAndTimestamp(i_feedId);
    // staleness checks ...
    return uint256(price).toInt256();   // <-- exponent never applied
}
```

`AaveOracle.getAssetPrice()` consumes this directly, assuming every price is in `BASE_CURRENCY_UNIT = 1e8` (8 decimals). The entire collateral/debt valuation therefore **silently relies on every Pyth feed having exponent == −8 forever**, with nothing on-chain enforcing it.

- **Current state is safe** — all 3 live feeds verified `exponent == -8` on-chain.
- **Latent risk** — a future-listed asset whose Pyth feed (or an upstream Pyth change) carries a different exponent misscales by orders of magnitude → drain via over-borrow or mis-liquidation. The classic "Nth-token-listed-post-audit" decimal trap A3 targets.
- **Not a live lead today** — triggering needs admin to list a non-(−8) feed, or Pyth to change a live exponent; neither is attacker-controlled.

Fix: normalize by exponent in `latestAnswer()`, or assert `exponent == EXPECTED` on every update.

Finding 2 — Dynamic decimals() reads latest entry

INFORMATIONAL / LOW

`decimals()` returns `uint8(uint16(-latestPrice.exponent))` from the most-recent entry, not a constant; `AggregatedPythPriceAdapter._aggregate()` scales by `10 ** secondary.decimals()`. Self-cancelling for the secondary leg, but a **primary**-exponent change shifts output scale (compounds Finding 1). A positive exponent would wrap to a large value → `10 ** big` reverts (DoS, not drain), reachable only by the trusted updater.

Finding 3 — Centralization (by design)

INFORMATIONAL

Adapter owners and PRICE_UPDATER_ROLE holders are EOAs/multisig that can set asset sources and push prices (standard Aave-admin trust). Not a code bug; monitor key custody.

4 • Honest Verdict

The Vena lending core is **canonical, unmodified Aave V3** — the audited, battle-tested path. The only bespoke attack surface is the Pyth oracle layer, which is defensively written (60s staleness, role-gating, signature verification, dual-feed timestamp guard).

No immediately-exploitable, fund-critical bug was found at the current on-chain state. The strongest lead is the latent A3 exponent-scaling fragility (Finding 1) — worth monitoring and re-checking on **every new asset listing**, but not a push-button drain today.

Next-best targets by EV (triage): #2 STRATO (CDP) • #3 Mezo Borrow (CDP) • #4 Venus Flux (Lending).